

LoadLead — Platform-Wide E2E Audit & Environment Reconciliation (v5)

Date: 2026-07-13 · **Scope:** backend, frontend-v2, infra (dev/staging/prod), live prod + staging · **Method:** 6 parallel audit dimensions (backend suite, frontend, environment parity, business-logic correctness, live black-box smoke, security/IAM/compliance) run against the codebase and live AWS account 552011299815. HIGH findings independently re-verified at the source.

1. Executive summary

The platform is **fundamentally sound and ships-ready on its core**: the backend suite is fully green (93 files / 739 tests, 0 flaky), the money layer's integer-cents discipline is genuinely strong, the negotiation state machine and Canopy webhook signature/replay are correct, no authentication bypass was found on 14 unauthenticated probes across both live environments, and prod is correctly muted (persona off, private-beta wall on). **No CRITICAL issue is active** — most importantly, prod's `JWT_SECRET` is set, so the one potentially-critical finding (an insecure default) is a latent landmine, not a live breach.

However, this round surfaced a consistent, higher-value theme than prior rounds: **controls that exist in code but are not wired to their enforcement point, and object-level authorization gaps**. Several shipped "gates" the platform believes it enforces are bypassable — an expired insurance certificate still reads as VERIFIED; the e-sign-at-assign attestation isn't bound to the driver being assigned; the private-beta wall fails *open* on the login page; legal holds and payout intercepts have **zero** production callers; and three factoring/BOL endpoints act on an object id without checking who owns it. Separately, **prod's entire runtime configuration is out-of-band** (no IaC source of truth), which is both a disaster-recovery risk and the root of the recurring "config got wiped/drifted" failures.

Tally: 16 HIGH, ~13 MEDIUM, ~16 LOW/informational. None block the current beta, but the HIGH authz/gate items should be closed before onboarding real carriers with money movement.

Severity counts by dimension

Dimension	CRIT	HIGH	MED	LOW	Health
Backend suite + build	0	0	0	4	Green — 739 tests pass, tsc clean
Frontend build/type/test	0	2	2	2	Green build/E2E; 2 gate/trust defects
Environment parity	0	4	3	2	Amber — prod config unmanaged; table drift
Business-logic correctness	0	2	2	5	Amber — 2 gate bypasses; cents solid
Live smoke (prod+staging)	0	1	2	1	Green core; CORS→500; staging hardening
Security / IAM / compliance	0	7	4	3	Amber — IDOR + unwired controls

2. Environment parity matrix

Dimension	dev	staging	prod	Verdict
Provisioned	No (code/config only)	Yes	Yes	dev intentionally unprovisioned
APP_ENV signal	n/a	staging	production	✓ correct lockdown key
Table prefix	LoadLead-Dev- (unused)	LoadLead-Staging-	LoadLead_ (+1 dash outlier)	⚠ prefix scheme differs prod vs staging
Boot-required GSIs	n/a	all ACTIVE	all ACTIVE	✓
Offers loadId-index	n/a	MISSING (500s)	present (separate def)	✗ EP-3
Canopy tables	n/a	present (2)	MISSING (unapplied)	✗ EP-2
Runtime config source	n/a	tfvars + main.tf (partial)	100% out-of-band	✗ EP-1
Canopy secrets durable	n/a	No (on-EB only)	n/a (unset)	✗ EP-4
Feature flags (beta/persona/kms)	n/a	full-app mirror	muted	✓ intentional
Security headers (FE)	n/a	none	full set	✗ LS-2
Canopy webhook route	n/a	mounted (401)	404 (build behind)	⚠ LS-3 deploy drift

3. Findings register

Legend: ✓ = independently re-verified at source during this audit. Others are agent-reported with cited file:line evidence.

HIGH

BL-1 ✓ — Mandatory-COI gate accepts an EXPIRED/REJECTED certificate. `services/canopy/verificationDecision.ts:111-114` computes `coiPresent = Boolean(getCurrent('HAULER', carrierId, 'COI'))`. `getCurrent` returns the *current-version* doc; COI expiry (`expireDueCois`) flips `verificationStatus` to EXPIRED but not `isCurrentVersion`, so a lapsed COI still counts as "present" and the hauler stays insurance-VERIFIED. Violates the stated rule "holds PENDING until a *current* COI exists" — it checks existence, not validity. **Impact:** a Canopy-connected hauler with a lapsed/rejected certificate transacts as fully insured. **COA:** gate on validity — `coiPresent = coiDoc && coiDoc.verificationStatus !== 'EXPIRED' && coiDoc.verificationStatus !== 'REJECTED'`; and have `expireDueCois` re-run `reevaluateCarrierInsurerPolicy`. Add a test that expires a COI and asserts the policy drops to PENDING.

BL-2 ✓ — E-sign-at-assign gate ignores the signature's bound driver. `routes/negotiations.ts:156-165` `requireCarrierAcceptForAssignment(loadId)` verifies only that a `CARRIER_ACCEPT` signature exists and its signer role — it never asserts `sig.assignedDriverId` equals the driver being committed (the doc comment says the sig "binds assignedDriverId," but the code doesn't check it). Signatures are per-load and not cleared on reject/expire. **Impact:** on a re-broadcast load, a different hauler can be assigned on a prior hauler's stale attestation — assignment completes with no attestation from the assigned party, defeating a shipped legal gate. **COA:** pass the assigned driver id and assert `sig.assignedDriverId === neg.haulerDriverId`; `requireSignature` already returns the sig.

FE-2 ✓ — Private-beta wall fails OPEN on login/signup. `pages/Login.tsx:170-179` and `pages/Signup.tsx:162-175` each re-implement their own non-retrying `/beta/status` fetch with `.catch(() => setBetaMode(false))` and the explicit comment "Fail-open to the normal login if `/beta/status` is unreachable." The shared `RuntimeConfigContext` correctly fails *closed*, but these pages bypass it. **Impact:** a single failed/slow `/beta/status` request exposes the public sign-in/sign-up form on the apex during the private beta. **COA:** delete the per-page fetch; consume `betaMode` from `RuntimeConfigContext` (fail-closed, retrying), or default `betaMode=true` on error.

FE-3 — Settings → Verification tab is a client-side mock. `pages/settings/SettingsPage.tsx:149-388` (Driver/Shipper/Receiver settings): zero backend calls; uploaded ID/selfie/business files are captured and silently discarded; "verified" status is written to `localStorage (ll_id_verif_<userId>)` and is trivially spoofable from devtools. It is disconnected from — and can contradict — the real Didit-backed flow at `pages/driver/DriverVerification.tsx`. **Impact:** users can believe they are verified when no verification occurred; support/trust confusion; a spoofable "verified" surface. **COA:** wire the tab to the real `/driver/verification/idv` flow, or remove it and route these personas to `DriverVerification`. Never persist verification state client-side.

LS-1 ✓ — Any non-allowlisted Origin header → 500 on every route (incl. `/api/health`). `index.ts:159` throws a plain `Error` for a rejected CORS origin; it has no `.statusCode`, so `middleware/errorHandler.ts:41` (`Number(err?.statusCode || err?.status ||`

500)) defaults it to 500 instead of a controlled 403. Confirmed live on both environments. **Impact:** fails safe (no data leak) but every route's error rate is trivially manipulable and `/api/health` is unreliable as a liveness signal when an Origin header is present. **COA:** `callback(null, false)` (lets cors send a clean response) or throw `new AppError('origin not allowed', 403)`; one-line fix, deploy once.

SEC-1 ✓ (prod safe) — JWT_SECRET insecure default with no boot guard. `config/environment.ts:201` `secret:` `process.env.JWT_SECRET || 'dev-secret'`; `bootGuard.ts` guards integration modes and table isolation but never `JWT_SECRET`. **Prod currently HAS JWT_SECRET set** (verified on `loadlead-backend-prod`), so this is latent — but given the platform's recurring out-of-band-env failure mode, an unset var in any deployed env silently makes every token forgeable (ADMIN 2FA does not help — forgery skips login). **Impact:** would be CRITICAL (ADMIN impersonation) the moment `JWT_SECRET` is missing on a live env. Fail-open by default is the wrong posture for the auth root of trust. **COA:** remove the `|| 'dev-secret'` fallback; add a fail-closed boot guard that refuses to start in staging/prod without a strong `JWT_SECRET` (mirror the never-live guard). Pin `algorithms: ['HS256']` on verify (SEC-12).

SEC-2 ✓ — Factoring release is an IDOR write. `routes/factoring.ts:341` → `services/factoringAssignmentService.ts:89` `release(assignmentId, actorId)` looks up the assignment by id and releases it with no check that `actorId` owns `target.carrierId`. **Impact:** any authenticated user releases any carrier's factoring assignment, flipping payee routing FACTOR→CARRIER (redirects who gets paid). **COA:** resolve the caller's carrier-of-record and assert `actor.carrierId === target.carrierId` (or platform-admin) before release.

SEC-3 — Factoring per-load opt-in is an IDOR. `services/factoring.ts:80` opt-in never checks carrier-of-record for the load. **Impact:** a carrier factors another carrier's delivered load; that load's BOL/POD are handed to the attacker's factor. **COA:** assert the caller is the load's carrier-of-record before creating the opt-in.

SEC-4 ✓ — BOL mutations are unguarded. `routes/bol.ts`: `requireBOLAccess` (party check) is applied to the GETs but not to `POST /:bolId/sign / update / wms / dispute`. The sign handler checks `role` (Driver/Receiver) but not that the caller is a party on *this* BOL's load. **Impact:** any DRIVER can sign any BOL → false PICKED_UP/DELIVERED attestations that drive factoring and settlement. **COA:** call `requireBOLAccess(req, bol)` at the top of every BOL mutation, not just reads.

SEC-5 — Legal holds are never enforced. `assertDeletable / isOnHold` have **zero** production callers; load/org/driver delete paths and the payout path never consult holds. **Impact:** a legal hold (compliance/counsel control) has no effect on live behavior — records/payouts under hold are not actually blocked. **COA:** invoke `assertDeletable` in every delete path and `isOnHold` at the payout seam; add integration tests that a held entity's delete/payout is rejected.

SEC-6 — Payout intercepts are bypassable (also BL-4). The live settlement seam `payeeRoutingService.resolvePayee` ignores intercepts; the only applier (`applyAtSettlement`) is reachable solely via `reconcileDebtorPayment`, which has **no callers**, and even then only when `payee==CARRIER` — a carrier under a factoring assignment routes to FACTOR and escapes the intercept (garnishment/levy/lien). **Impact:** court-ordered payout intercepts do not fire on the real settlement path. **COA:** apply intercepts inside `resolvePayee` (or a mandatory wrapper) for *all* payee branches; wire `reconcileDebtorPayment` or fold its logic into the live path; add a test that an intercepted carrier's payout is withheld on both CARRIER and FACTOR branches.

SEC-7 — Audit-log immutability is app-convention only. Only the Signatures table has an IAM-Deny + WORM S3 sink (and the DDB Deny is out-of-band; the `iam_signatures` module is unwired). `AdminAuditLog / LegalHolds / Adjudications / Disclosures / PayoutIntercepts` have no item-level Deny and no WORM, and the EB instance role holds `UpdateItem / DeleteItem` on all prefix tables. **Impact:** "append-only/immutable" compliance records are only immutable by convention; a bug or a compromised instance role can rewrite them. **COA:** add condition-expression guards (`attribute_not_exists` on update) at minimum; ideally an IAM Deny on `UpdateItem/DeleteItem` for the audit/compliance tables and a WORM export for the legally-sensitive ones. Wire the `iam_signatures` module.

EP-1 — Prod's entire runtime config is out-of-band (no IaC). `envs/prod/eb-imported.tf:57-67` sets `lifecycle { ignore_changes = [setting] }` with no `setting{}` blocks, so prod's APP_ENV, KMS key id, table overrides and all secrets have no Terraform source of truth and no drift detection. **Impact:** a recreate/DR loses the entire prod config and the env won't boot (fail-closed); no way to review or reproduce prod config from code. **COA:** codify prod env-vars in `eb-imported.tf` (non-secrets inline, secrets via a gitignored `prod.auto.tfvars`), matching the staging pattern; then a recreate is safe and config is reviewable.

EP-2 — Canopy prod tables are defined but unapplied. `envs/prod/canopy.tf` declares `LoadLead_CarrierInsuranceConnections` + `LoadLead_CoiCrossReferenceResults`; neither exists in prod AWS. **Impact:** inert today (prod has no Canopy secrets), but the day Canopy is enabled in prod the first write 500s — and prod force-locks Canopy to `production` with no sandbox fallback. **COA:** `tofu apply` the two tables in prod now (harmless empty tables) so enabling Canopy later is config-only; add them to the boot-required-GSI/table check.

EP-3 — Staging Offers is missing loadId-index → 500s. The shared `modules/dynamodb_tableset` omits it; `offerService.getOffersByLoad` queries it with no fallback. Prod has the index via a *separate* definition (`imported-tables.tf`), so the two schemas drift by construction. **Impact:** `getOffersByLoad` 500s on staging; latent divergence risk anywhere the two table definitions differ. **COA:** add `loadId-index` to the shared module and `tofu apply` staging; reconcile prod's `imported-tables.tf` to reference the same module so the schemas can't drift.

EP-4 ✓ — Canopy secrets are non-durable, and the code comment claims otherwise. `CANOPY_CLIENT_ID/SECRET/WEBHOOK_SECRET` live only on the staging EB env; `staging.auto.tfvars` has no Canopy keys (TF desires 32 env vars vs 35 live = exactly the 3 secrets).

`envs/staging/main.tf:255-260` (committed earlier today, PR #66) states they are in tfvars "so a recreate can never wipe them again" — **the durability fix was documented but not actually done. Impact:** a full env recreate wipes all three (it already happened once); the misleading comment could cause a future engineer to skip the real fix. **COA:** move the 3 secrets into `backend_env_vars` in `staging.auto.tfvars`, `tofu apply`, and correct the `main.tf` comment. *(This is the platform team's own item — fixing the comment immediately.)*

MEDIUM

- **BL-3 — Accessorial charge double-bill risk.** Charge id keyed on `policyHash` (`accessorialChargeService.ts:96,161`); a `policy-hash` change between two `computeForStop` calls mints a second billable charge (and supplemental advance) for the same stop. Latent today (only `freezeAndAgreeAtPosting` changes the hash, at posting) — gated by workflow ordering, not by code. **COA:** key the charge id on `(loadId, stopId, chargeType)` independent of policy hash.
- **BL-4 — Payout-intercept escape on the FACTOR branch** (see SEC-6). May be accepted legal behavior once the receivable is sold — confirm with counsel and document.
- **FE-1 — No frontend unit-test CI gate.** `npm test` (`vitest`) exits 1 because it also globs the 5 Playwright specs (no `test.exclude` in `vite.config.ts`); the 21 real unit tests pass. No workflow runs the unscoped command, so FE unit tests aren't gated. **COA:** add `test.exclude: ['e2e/**']`; add a CI job running FE unit tests.
- **FE-4 — tour-vendor (shepherd.js) eager-loaded on every route** via `modulepreload` because `AppLayout / App.tsx` import it statically, contradicting its "lazy-route-only" comment. Bytes, not a crash. **COA:** lazy-import the tour.
- **LS-2 — Staging FE serves zero security headers** (no CSP/HSTS/X-Frame-Options/X-Content-Type-Options/Referrer-Policy); prod FE has the full set. **COA:** attach the prod CloudFront Response Headers Policy to the staging distribution.
- **LS-4 — Staging is fully crawlable/indexable** (no robots disallow, no noindex, no `X-Robots-Tag`) while hosting the deliberately-muted pre-release persona. **COA:** add `X-Robots-Tag: noindex` (or a `robots.txt` disallow) on the staging distribution.
- **EP-5 — Staging tofu plan is not clean:** 0 add, 1 change, 0 destroy (EB env, 43 settings rewritten each plan). **COA:** reconcile the perpetual EB settings diff (the out-of-band vars are the cause — closing EP-4 largely closes this).
- **EP-6 — Loads status-createdAt-index** present in staging/module, absent in prod (unused by code; drift only). **COA:** reconcile definitions.
- **EP-7 — Isolation-guard blind spot:** `prodFormTableNames` (`bootGuard.ts:111`) only flags the `LoadLead_` underscore prefix, so the dash-named prod table `LoadLead-MembershipAuditLogs` would slip past the runtime guard (masked today by the wired CI parity check). **COA:** normalize the guard to catch both prefixes.
- **SEC-8 — Factoring read leaks:** factoring payee/package reads expose any load's net pay + debtor to a non-owner. **COA:** ownership-gate the reads (same fix family as SEC-2/3).
- **SEC-9 — OO DELETE /fleet/:driverId orphans another operator's driver:** nulls `ownedByOperatorId` on an unvalidated `driverId`. **COA:** assert the driver's `ownedByOperatorId === caller`.
- **SEC-10 — Shared github_oidc_role module = prod deploy-role blast radius.** Per-env instances are correctly scoped today, but any module edit changes the prod deploy identity. **COA:** standing caution + a review gate on module edits (documented; not an active vuln).

LOW / informational

- **BE-1 — Node 22 runway:** AWS SDK v3 will require Node ≥ 22 for releases after early Jan 2027; repo on node 20.20.0. Schedule the EB-platform + CI + `.npmrc` bump before Q1 2027 (highest-value LOW).
- **BE-2 —** add a dedicated `accessorialCalc` unit test for cap/boundary edges (currently covered only transitively).
- **BE-3 —** Pact provider verification is excluded from `npm test`; ensure the dedicated CI step runs it.
- **BE-4 —** `npm warn ... ignoring workspace config at backend/.npmrc`; confirm `.npmrc` isn't load-bearing.
- **FE-5 —** `PrivateBetaLanding.tsx` is both static- and dynamic-imported; its `lazy()` is a no-op.
- **FE-6 —** `playwright.config.ts:9` hardcodes an absolute single-dev report path inside the tracked `docs/overnight-2026-07-03` folder; running E2E left two files locally modified (visible in `git status`). Revert those and relocate the report path.
- **LS-3 — Prod /api/webhooks/canopy 404s** (route not registered) while staging serves it (401, signature enforced) → prod backend is a few commits behind `main` /staging on the Canopy handler. Fails safe (prod connect-disabled), but is a real deploy-parity signal. **COA:** redeploy prod backend from `main` so `prod ≤ 1` deploy behind.
- **BL-5 —** `setVerificationStatus` has no transition guard (terminal protection is ad-hoc per caller; the accessorial ledger's `assertTransition` is the model to copy).
- **BL-6 —** narrow terminal-resurrection race in the Canopy decision (read-once terminal check before async work).
- **BL-7 —** `resolveInvoicePayee` routes to FACTOR only on 'SUBMITTED'; a 'FUNDED' opt-in falls through to CARRIER. Confirm intended.
- **BL-8 —** DynamoDB TTL unit inconsistency (org invite/token `expiresAt` in ms vs outbox in seconds); verify which tables actually enable TTL.
- **BL-9 —** Canopy auto-populate rounds cents→dollars for display only (no decision impact).
- **SEC-12/13/14 —** pin `jwt.verify` algorithms; stop logging invitation tokens + factoring payloads; add a party check to `GET /compliance/policy/load/:loadId`.

- **EP-8** — never-live guard omits `kms` (staging runs `KMS_MODE=live` intentionally); fmcsa/maps warn-only by design.

4. Courses of action (COAs)

COA-1 — Close the HIGH authz/gate bypasses (this week; small PRs, no migration)

The cheap, sharp, high-value fixes. Each is a localized code change with a bypass-test:

1. **BL-1** COI validity gate + re-evaluate on expiry.
2. **BL-2** assert `sig.assignedDriverId` at assign.
3. **FE-2** beta wall consumes the fail-closed RuntimeConfig.
4. **LS-1** CORS reject → 403 not 500.
5. **SEC-1** remove `dev-secret` fallback + JWT boot guard + pin algorithms.
6. **SEC-2/3/4/8/9** add carrier-of-record / party ownership checks to factoring release, factoring opt-in, BOL mutations, factoring reads, OO fleet delete.

Each fix must land with a test that proves the *NEGATIVE* (bypass attempt → rejected).

COA-2 — Wire the unwired controls (next sprint)

The "control exists but isn't called" class — needs integration + tests at the seam:

1. **SEC-5** call `assertDeletable` / `isOnHold` on all delete + payout paths.
2. **SEC-6** apply payout intercepts in `resolvePayee` for all payee branches; wire `reconcileDebtorPayment`.
3. **FE-3** wire (or remove) the mock verification tab to the real Dedit flow.
4. **SEC-7** condition-expression guards + IAM-Deny/WORM on compliance/audit tables; wire `iam_signatures`.

COA-3 — Environment reconciliation & IaC source-of-truth (platform; before beta scale-up)

1. **EP-1** codify prod runtime config in IaC (biggest structural gap).
2. **EP-4** move Canopy secrets to `staging.auto.tfvars`; fix the false `main.tf` comment (*done this session*).
3. **EP-3/EP-6** unify staging + prod table definitions on the shared module; add `Offers loadId-index` to staging.
4. **EP-2** apply the 2 Canopy prod tables.
5. **LS-2/LS-4** staging FE: security-headers policy + noindex.
6. **EP-5/EP-7** reconcile the perpetual EB plan diff; normalize the isolation guard for both prefixes.

COA-4 — Hygiene backlog (opportunistic)

BE-1 (Node 22 before Q1 2027), BE-2/3/4, FE-1/4/5/6, BL-3/5/7/8/9, SEC-10/12/13/14, EP-8, LS-3 (redeploy prod from main).

5. Recommendations (standing practice)

1. **Every gate needs a negative test.** The recurring pattern (BL-1, BL-2, FE-2, SEC-5/6) is a gate that passes its happy-path test but was never tested for the *bypass*. Adopt: for each security/compliance gate, a test that asserts the rejected case.
 2. **Authorization ≠ authentication.** SEC-2/3/4/8/9 are all "authenticated but not authorized for *this* object." Add an IDOR checklist to review: every `get/mutate-by-id` must assert ownership. Consider a shared `assertOwnsResource` helper used uniformly.
 3. **IaC is the only source of truth for env config.** The out-of-band pattern (Canopy secrets, prod config EP-1/EP-4) has now caused multiple incidents. No env var should exist on an EB env that isn't in Terraform. Add a CI check comparing deployed EB settings to TF-desired.
 4. **"Wired" is part of "done."** A control (legal hold, intercept) is not shipped until an integration test proves it is *invoked* at the seam, not merely that the helper works in isolation.
 5. **Deploy parity.** Keep prod ≤ 1 deploy behind `main` (LS-3 shows prod drift). Consider auto-deploying prod backend on merge behind the existing gates.
 6. **Fail closed on trust boundaries.** Auth secret (SEC-1) and the beta wall (FE-2) both currently fail open; every trust-boundary default should fail closed.
-

6. Method & evidence

Six independent audit agents ran in parallel against the live repo and AWS account 552011299815 (us-east-1): backend suite (`vitest run + tsc`), frontend (`tsc / vite build / vitest /Playwright`), environment parity (live `aws dynamodb / elasticbeanstalk describe* + tofu plan` across staging & prod), business-logic trace (8 critical paths), live black-box smoke (curl vs prod + staging, 14 unauth probes + gate behavior), and security/IAM/compliance (auth middleware, all sensitive routers/services, IaC). Staging was resumed for live smoke and re-paused after. All HIGH findings were re-verified at the cited source before inclusion. Per-dimension evidence files (`01 – 06`) and raw command logs are retained in the audit workspace.

Prepared by Platform Engineering · Audit v5 · 2026-07-13.